Policy 16 – Logging, Monitoring & Audit

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Log Collection & Centralisation

2.4 Log Retention & Protection

2.5 Real-Time Alerting

2.6 Audit & Review

2.7 Clock Synchronisation

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Provide trustworthy evidence for security, troubleshooting, and compliance by collecting and analysing relevant logs.

2.2 Scope – Application, system, network, authentication, and cloud-provider logs across all environments.

2.3 Log Collection & Centralisation

- Forward logs to a central, access-controlled SIEM or log service.
- Include timestamp, user, event type, source IP for security-relevant events.

2.4 Log Retention & Protection

- Retain security logs at least 90 days online and 1 year archive.
- Restrict write access to logging system; prohibit log tampering or deletion.

2.5 Real-Time Alerting

- Create alerts for key events: failed admin logins, privilege escalations, critical errors.
- Send alerts to on-call channel; maintain documented runbooks.

2.6 Audit & Review

- Review alert metrics and random log samples monthly.
- Produce quarterly audit report summarising anomalies and actions.

2.7 Clock Synchronisation

- Sync all servers and devices to trusted NTP source; alert on drift >5 s.

3. Policy Compliance

3.1 Compliance Measurement – Central platform receives ≥ 95 % of target logs; alert queue triaged within SLA.

3.2 Exceptions – Systems unable to forward logs must export daily and upload; document in asset list.

3.3 Non-Compliance – Logging gaps >24 h or unreviewed alerts escalated to incident response.

3.4 Continual Improvement – Add new log sources and refine alert logic based on incident learnings.